



PA-DSS implementation guide

BASE24-atm™
BASE24-pos™

Contents

About this document.....	4
Audience	4
Prerequisites.....	4
Additional Documentation.....	4
1: Getting started — addressing PA-DSS security requirements	5
2: Non-retention of sensitive data	6
Non-retention of data after authorization.....	7
Non-retention of data used in debugging or troubleshooting.....	8
Non-retention of data removed from encrypted disks	8
Deleting information securely using CLEARONPURGE	9
3: Protection of stored cardholder data	10
Periodic removal of cardholder data	10
Protection of data at rest.....	10
Masking displayed information	11
Restrict access to data by business need-to-know	12
Controlling access to printed reports	12
4: Secure authentication features	13
Administrative IDs.....	13
User IDs.....	13
Passwords	14
Complex passwords	14
Password Aging	15
Password Histories	15
System Lockout	15
5: Logging of payment application activity	16
Logon/Logoff Access Report	17
File Access Report.....	18
6: Protecting wireless transmissions.....	20
7: Isolating cardholder data from the Internet.....	21
8: Facilitating secure remote software updates.....	22

9: Facilitating secure remote access to the payment application	24
10: Encryption of sensitive traffic over public networks.....	26
11: Encryption of all non-console administrative access	27
Copyright information.....	28

About this document

This document provides guidance to support compliance with the Payment Card Industry (PCI) Data Security Standard (DSS), and serves as a Payment Application Data Security Standard (PA-DSS) implementation guide for BASE24. This document is reviewed and updated annually or when there are changes to the BASE24 application or the PA-DSS requirements.

Audience

This document is intended for security administrators, application managers, and persons responsible for the secure installation and configuration of the BASE24 system. Operations managers, security auditors, and change management personnel can also use this document when evaluating and implementing the security practices of your organization.

Prerequisites

This document is designed to be used in conjunction with your corporate information security policies. Readers should be familiar with their internal policies and the security information in the BASE24 user security manual.

Additional Documentation

This manual contains references to the following BASE24-eps publications:

- The ***BASE24 user security manual*** describes how to assign access to BASE24 screens. It also describes how to run audit reports on the Online Maintenance File (OMF).
- The ***BASE24 Logical Network Configuration File manual*** contains detailed descriptions of the parameters used to configure system security.
- The ***ACI desktop user interface manual*** describes user access configuration for those systems that use the Enhanced Authorization product or the Transaction Security Services process.
- The ***Payment card industry payment application data security standard***, that is available through the PCI website is cited as a reference for industry security best practices.

1: Getting started — addressing PA-DSS security requirements

The **PA-DSS implementation guide** describes security considerations in the configuration and operation of a BASE24 application environment that can help you address the following PA-DSS security requirements:

- Non-retention of sensitive data
- Protection of stored cardholder data
- Secure authentication features
- Logging of payment application activity
- Protecting wireless transmissions
- Isolating cardholder data from the Internet
- Facilitating secure remote software updates
- Facilitating secure remote access to the payment application
- Encryption of sensitive traffic over public networks
- Encryption of all non-console administrative access

The remainder of this document describes how the BASE24 product features can be used to comply with these requirements.

2: Non-retention of sensitive data

For acquirer and issuer transactions, it is possible to configure the BASE24 product to store and/or transmit sensitive authentication information, including full track information, service codes, card-validation codes, and PIN verification values (PVV). The default Logical Network Configuration File (LCONF) delivered with the BASE24 product has the parameters set to suppress storage and transmission of this sensitive authentication information. You are responsible to ensure that these configuration parameters are set to suppress storage and transmission of full track data in order to meet PCI-DSS requirements.

Some interfaces may require this sensitive data to process reversals. However, modifying these parameters so that full track data is stored or transmitted will make the system noncompliant with PCI-DSS requirements. The following is a list of LCONF parameters that must be set to the value Y to achieve PCI-DSS compliance. See the **BASE24 Logical Network Configuration File manual** for a description of each parameter.

Switch Parameters

ELIMINATE-ACQ-TRK-DATA
SWI-ACQ-AVS-DATA-SUPPRS
SWI-ACQ-CVD2-DATA-SUPPRS
SWI-ACQ-DISCR-DATA-SUPPRS
SWI-ISS-AVS-DATA-SUPPRS
SWI-ISS-CVD2-DATA-SUPPRS
SWI-ISS-DISCR-DATA-SUPPRS

ATM Parameters

ATM-ACQ-DISCR-DATA-SUPPRS
ATM-DISCR-DATA-STM-SUPPRS
ATM-ISS-DISCR-DATA-SUPPRS

POS Parameters:

POS-ACQ-AVS-DATA-SUPPRS

POS-ACQ-CVD2-DATA-SUPPRS

POS-ACQ-DISCR-DATA-SUPPRS

POS-DISCR-DATA-PSTM-SUPPRS

POS-ISS-AVS-DATA-SUPPRS

POS-ISS-CVD2-DATA-SUPPRS

POS-ISS-DISCR-DATA-SUPPRS

LCONF parameters are set and modified through the LNCF Param screen of the BASE24 CRT access system. See the ***BASE24 Logical Network Configuration File manual*** for instructions regarding updating, adding, and deleting LCONF parameters. You also must restrict access to the LCONF at the application and operating system level, so that these parameters are not compromised.

PINs and/or PIN blocks received by BASE24 in transaction messages are not stored by the BASE24 system.

Non-retention of data after authorization

Note that the BASE24 product receives sensitive data and stores it in memory during the life of the transaction. The BASE24 product clears information from memory when the information is no longer needed to process a transaction. Also, you can configure the maximum Store-and-Forward File retries fields in the Host Configuration File and Interchange Configuration File to limit the number of times the Host Interface or Interchange Interface process can attempt to send the store-and-forward message before deleting it. The interface process attempts to send the store-and-forward message only as many times as specified in the field before deleting it.

Logical Network Configuration File parameters give you the ability to suppress the following types of sensitive authentication information:

- BASE24-pos acquirer address verification data
- BASE24-pos acquirer card verification data
- BASE24-pos acquirer discretionary data
- BASE24-atm acquirer discretionary data
- BASE24-pos issuer address verification data
- BASE24-pos issuer card verification data
- BASE24-pos issuer discretionary data
- Interchange Interface process address verification data
- Interchange Interface process card verification data
- Interchange Interface process discretionary data

Parameters that control this information are described in the **BASE24 Logical Network Configuration File manual**. To be compliant with PCI DSS, BASE24 must be configured to prohibit storing this sensitive card information.

You are responsible for restricting access at the application and operating system levels to files that contain sensitive data. The following is a sample list of files that contain sensitive data:

- Cardholder Authorization File
- Positive Balance File
- BASE24-atm Terminal Data Files
- BASE24-pos Terminal Data Files
- Store-and-Forward File
- XPNET Audit Files
- Dump files

Disclaimer: This may not be a complete list. You should perform your own assessment of BASE24 files and evaluate the sensitivity of the data in each file for yourself.

Non-retention of data used in debugging or troubleshooting

The BASE24 and XPNET products have the capability of running in debug mode. Customers should use this function very carefully, as the information being placed in the debug files has extremely sensitive information pertaining to cardholder information:

- Collect sensitive authentication data only when needed to solve a specific problem.
- Store data in specific, known locations with limited access.
- Collect only a limited amount of data needed to solve a specific problem.
- Encrypt sensitive authentication data while stored.
- Securely delete collected data immediately after use.

Non-retention of data removed from encrypted disks

If disk encryption is implemented in the BASE24 environment, any data removed from the system, such as backups, debug files, logs and trace files will be in the clear. Encryption must be implemented to protect sensitive data removed from the BASE24 environment.

Deleting information securely using CLEARONPURGE

To be PCI DSS compliant, magnetic stripe data, card validation codes, PINs, and PIN blocks stored by previous versions of the application must be removed by wiping these files using the CLEARONPURGE option (see note below). On the HP NonStop platform, files can be securely deleted by first setting the CLEARONPURGE option of the FUP SECURE command. For example, execute the following FUP commands to wipe the file *myfile*:

```
FUP SECURE myfile, , CLEARONPURGE  
PURGE myfile
```

The following files must have the CLEARONPURGE flag set to ensure that they are securely deleted when purged:

- Interchange Log File (ILF)
- Transaction Log File (TLF)
- POS Transaction Log File (PTLF)
- Store and Forward File (SAF)
- Resubmittal Store and Forward File (RSAF)

Note: The CLEARONPURGE option, available for diskfiles, may be set to physically overwrite the residual data from any files which have been deleted (i.e. purged). Because every block of the purged file is overwritten with binary zeros, CLEARONPURGE requires extra I/O operations and disk channel time. This added overhead increases proportionally with file size. The increase is hardly noticeable on a small file, but can be many minutes of elapsed time on a large file.

CLEARONPURGE should be designated for files containing particularly sensitive data. Other files should be evaluated by the organization to weigh the risk of not clearing the deleted file against system performance considerations.

3: Protection of stored cardholder data

Periodic removal of cardholder data

The BASE24 system automatically removes data from previous transactions after a configurable number of days. This is done to facilitate reversals. In order to be PCI compliant, the system must be configured to retain this data for not more than 7 days. See the **BASE24 Logical Network Configuration File manual** for information on setting the SWI-ILF-FILERETENTION flag that controls this feature.

On the HP NonStop platform, files can be securely deleted by first setting the CLEARONPURGE option of the FUP SECURE command. The following files must use the CLEARONPURGE option ensure that they are securely deleted when purged. Refer to section 2 for more information about the CLEARONPURGE option.

- Interchange Log File (ILF)
- Transaction Log File (TLF)
- POS Transaction Log File (PTLF)
- Store and Forward File (SAF)
- Resubmittal Store and Forward File (RSAF)

Protection of data at rest

The BASE24 product does not provide data level encryption to protect cardholder data. To be PA-DSS compliant, users must implement a disk level encryption solution on their HP NonStop platform. Any implemented disk level encryption solution must adhere to the following PCI DSS requirements:

- Logical access to encrypted file systems must be implemented via a mechanism that is separate from the native operating systems mechanism (for example, not using local user account databases).
- Cryptographic keys must be stored securely (for example, stored on removable media that is adequately protected with strong access controls).
- Cardholder data on removable media must be encrypted wherever stored.

Additionally, you must fully document and implement all cryptographic key management processes and procedures for cryptographic keys used for encryption of cardholder data, including the following:

- Cryptographic key access must be restricted to the fewest number of custodians necessary.
- Cryptographic keys must be securely stored in the fewest possible locations and forms.
- Strong cryptographic keys must be generated.
- Cryptographic key distribution must be secure.
- Cryptographic key storage must be secure.
- Cryptographic keys must be changed periodically:
 - As deemed necessary and recommended by the associated application (for example, re-keying); preferably automatically
 - At least annually
- Old or suspected compromised cryptographic keys must be replaced.
- Knowledge of cryptographic keys must be split between multiple key custodians with provisions for dual control over cryptographic keys.
- Unauthorized substitution of cryptographic keys must be prevented.
- Cryptographic key custodians must be required to sign a form stating that they understand and accept their key custodian responsibilities.

To achieve PCI DSS compliance, any cryptographic key material or cryptogram stored by previous versions of the payment application, and used to encrypt or verify cardholder data, must be securely deleted in accordance with industry-accepted standards for secure deletion, as defined, for example the list of approved products maintained by the National Security Agency, or by other State or National standards or regulations. Refer to your disk encryption systems documentation to determine how cryptographic material can be removed and how to re-encrypt historic data with new keys.

Masking displayed information

The BASE24-atm product enables you to mask cardholder information on customer receipts. By using the account number truncation feature, you can substitute blank spaces or pad characters for part of the card number and account numbers on ATM customer receipts. Cross-industry best practices recommend displaying only the last four digits or the first six digits. The middle six digits should never be displayed. Refer to the device-specific device support manuals for more information about account number truncation.

Note that the BASE24-pos product does not control POS receipt printing. It is your responsibility to communicate your organization's policies with your POS merchants.

Restrict access to data by business need-to-know

Restricting access to information to only those who need it to perform their jobs ensures that critical data can only be accessed in an authorized manner. It is your responsibility to review the BASE24 user access screens and the associated documentation to determine whether the screens contain sensitive information that should be protected.

It is your responsibility to grant access to BASE24 screens on a business need-to-know basis only. You can use BASE24 Security screen 3 to define the type of access (read, add, delete, update) each user has to each BASE24 screen. The default value is no access. Refer to the BASE24 User Security Manual for more information about assigning screen access.

You can use the BASE24 user access security screens to restrict access to the BASE24 system as follows:

To Restrict a User's Access to...	Use this Screen
Information at the financial institution level	Security File, screen 2
Information at the regional or branch level	Security File, screen 2
The XPNET node to which commands are sent	Security File, screen 1
Information based on the time of day	Security File, screen 1
Terminals that can be used to access BASE24 data	Security File screen 1
BASE24 user access screens containing sensitive information	Security File screen 3

Because a single user can have access to multiple logical networks, you can use these screens to configure restrictions on each logical network to which the user has access.

Refer to the **BASE24 user security manual** for more information about using the Security File screens to restrict access using these controls. If you have the

Enhanced Authorization product or the Transaction Security Services product, refer to the ACI Desktop User Interface Manual for more information about assigning access to the ACI desktop user interface.

Controlling access to printed reports

Should reports be printed from the BASE24 database, it is your responsibility to ensure that those reports are printed in areas where the information would not be easily accessed.

4: Secure authentication features

Unique user IDs ensure that actions taken on critical data and systems are performed by, and can be traced to, known and authorized users. The BASE24 product allows you to configure unique user IDs and passwords. A user ID and password are required to log on to the BASE24 user access system.

To be PCI DSS compliant, all subsystems with access to the BASE24 payment application, such as PCs, servers, and databases, must be assigned a unique user ID and secure authentication.

Administrative IDs

Personnel who perform administrative duties (for example, setting screen access for all other users of the BASE24 system) must log on to the system with a unique ID. To be PCI DSS compliant, shared administrative IDs must not be used. Cross-industry best practices recommend reserving the use of administrative IDs to a security officer in your organization. Note that these IDs are meant for administrative purposes and should not be used to access the application for day to day use.

To be PCI DSS compliant you must not use default administrative accounts for logins to the BASE24 system. Any default administrative accounts must be assigned secure authentication and disabled or not used. Refer to the BASE24 User Security Manual for more information about configuring IDs.

In addition to assigning a unique ID, employ at least one of the following methods to authenticate all users:

- Password or passphrase
- Two-factor authentication (for example, token devices, smart cards, biometrics, or public keys)

User IDs

Each user of your BASE24 system must have a unique user ID and password. BASE24 Security screen 1 enables you to create user IDs and assign passwords. If your organization uses the Enhanced Authorization product or the Transaction Security Services process, you also must configure unique IDs for the ACI desktop user interface.

Refer to the BASE24 User Security Manual for more information about assigning access and the Security File screens. Refer to the ACI Desktop User Interface Manual for more information about assigning access to the ACI desktop user interface.

Note: The procedures described here are for setting unique IDs for the BASE24 user access system only. It is your responsibility to assign unique IDs to each person at the operating system level.

Passwords

All user IDs must be associated with a password to ensure that only authorized users can log on to the BASE24 user access system. Users are required to enter their passwords on the BASE24 Logon screen. As you create user IDs for BASE24 users, you must set first-time passwords to a unique value per user. To be PCI DSS compliant, your password policies must explicitly prohibit the use of shared or group passwords. Shared or group passwords must not be distributed, even if requested.

Cross-industry best practices recommend requiring users to change their first-time passwords immediately after first use. Refer to the BASE24 User Security Manual for more information about changing passwords.

ACI recommends distributing password policies and procedures to all users who have access to cardholder information. Passwords stored in the BASE24 system are hashed. Cross-industry best practices advocate the use of complex passwords, password aging, and password histories to prevent unauthorized users from using an ID by guessing the password.

Complex passwords

Cross-industry best practices advocate the use of complex passwords for all BASE24 logons. You can specify the use of complex passwords by setting the complex passwords parameter in the Logical Network Configuration File. If the parameter is set to require complex passwords, you then can specify the minimum length of the password; whether the password is case sensitive; the number of alphabetic, numeric, and special characters required; the password change interval; and the number of passwords stored.

To be PCI DSS compliant, the password parameters must be configured to the following minimum settings. Modifying these default settings to a level below the minimums will make the system non-compliant with the PCI DSS standard:

Complex Password Characteristic	Logical Network Configuration File Parameter
Minimum password length of seven characters	Minimum password length
Use of alphabetic, numeric, and special characters. The minimum alpha and minimum numeric characters parameters must be set to a value greater than 0.	Minimum number of alphabetic characters Minimum number of numeric characters Minimum number of special characters
Mixed case	Complex password
Change password at least every 90 days	Password change interval
Do not allow a password that is the same as any of the last four passwords	Maximum passwords stored

Refer to the **BASE24 user security manual** for more information about complex passwords. Refer to the **BASE24 Logical Network Configuration File manual** for more information about the Logical Network Configuration File parameters related to passwords.

Password Aging

Passwords must be changed frequently to reduce risks of compromised passwords. To be PCI DSS compliant, you must require users to change their passwords at least every 90 days. You can use the password change interval parameter in the Logical Network Configuration File to configure how often a password must be changed.

You also can configure the number of times a day a password can be changed using the maximum password changes per day parameter in the Logical Network Configuration File.

Password Histories

To be PCI DSS compliant you must not allow an individual to submit a new password that is the same as any of the last four passwords he or she has used. The Logical Network Configuration File maximum stored passwords parameter specifies the number of passwords stored in the password history. The BASE24 product allows up to 10 passwords to be stored in the password history. A user is unable to reuse any password contained in his or her password history.

System Lockout

To be PCI DSS compliant users must be locked out of the system after no more than six login attempts or after the session has been idle for 15 minutes. The maximum logon attempts Logical Network Configuration File parameter and corresponding field in the Security File specify the number of unsuccessful login attempts a user can have before being locked out of the BASE24 environment. The logoff interval configured in the Logical Network Configuration File and the Security File specify the length of time a session can be idle before logging the user out. In the BASE24 system, once user accounts are locked out, they must be re-activated by the application administrator.

5: Logging of payment application activity

The BASE24 product uses the Online Maintenance File (OMF) to store detailed information about each BASE24 record that is added, deleted, or updated using the BASE24 user access system. This includes any actions taken by an individual with administrative privileges. You can enable or disable auditing by setting the Logical Network Configuration File (LCNF) parameter for OMF audit. OMF auditing is enabled by default and must be enabled to be compliant with PCI DSS. Modification to the LCNF file is done through the BASE24 user access system and is therefore audited.

When an operator reads, adds, or updates any file record or table row in the BASE24 system, the Online Maintenance File (OMF) is updated with the details of the action. The OMF contains detailed records of each record or row read, added, updated, or deleted in the logical network. For reads, an OMF record is written only if the record being read contains sensitive cardholder data, e.g., a PAN.

The OMF is used to generate two reports that include information from a single day's OMF file(s), displayed in timestamp order.

- **Logon/Logoff Access Report.** Provides identification and authorization, as well as logical access information on users who have logged on to or attempted to log on to the BASE24 Pathway system and on users who have logged off from the Logon screen.
- **File Access Report.** Provides information on users who have read, added, updated, or deleted records in BASE24 files accessed through the BASE24 Pathway system, as well as information on users who have logged on to the BASE24 Pathway system and users who have logged off from the Logon screen.

There are summary and detail versions of both OMF audit reports. Your configuration determines whether the data is available to create the summary and detail versions of these reports. By default, before and after images of modified rows are not present in the OMF record.

Use the OMF to track access to cardholder data and to run the OMF report often. Refer to the **BASE24 Logical Network Configuration File manual** for more information about the OMF audit parameter. Refer to the **BASE24 user security manual** for information about running OMF audit reports.

Note: Creation and deletion of system level objects is captured in the Guardian Operating System log file.

Logon/Logoff Access Report

The Logon/Logoff Report contains the following information:

INPUT FILE — The fully-qualified name of the first OMF file, as specified in the runfile. This information is displayed at the top of each page.

REC NUM — The record number from the OMF file that contains the information shown for this line of the report. These numbers start over from 0 for each input file. You can use the record number, which is the key to the OMF, to display an individual record or to capture a record image for further analysis. For example, you can use the FUP COPY command with a record number to display the OMF record associated with that record number.

DATE — The date on which the file maintenance operation, the logon attempt, or the logoff was performed. The date is displayed in YYMMDD format.

TIME — The time of day at which the file maintenance operation, the logon attempt, or the logoff was performed. The time is displayed in HHMM format.

GROUP — The numeric identifier for the group to which the user belongs.

USER — The numeric identifier for the user.

LOGON/LOGOFF — If the record is a logon record, LOGON is displayed. If the record is a logoff record, LOGOFF is displayed.

LNET — The identifier for the logical network that the user entered on the Logon screen.

FIID — The identifier for the financial institution for which the user performed file maintenance. This field is always blank.

REGION — The identifier for the region for which the user performed file maintenance. This field is always blank.

BRANCH — The identifier for the branch for which the user performed file maintenance. This field is always blank.

TERMINAL ID — The identifier for the terminal from which the user performed the file maintenance operation, logon attempt, or logoff.

File Access Report

The File Access Report contains the following information:

INPUT FILE — The fully-qualified name of the first OMF file, as specified in the runfile. This information is displayed at the top of each page.

REC NUM — The record number from the file that contains the information shown for this line of the report. These numbers start over from 0 for each input file. You can use the record number, which is the key to the OMF, to display an individual record or to capture a record image for further analysis. For example, you can use the FUP COPY command with a record number to display the OMF record associated with that record number.

DATE — The date on which the file maintenance operation, the logon attempt, or the logoff was performed. The date is displayed in YYMMDD format.

TIME — The time of day at which the file maintenance operation, the logon attempt, or the logoff was performed. The time is displayed in HHMM format.

FILE ID — The standard BASE24 abbreviation for a file. OMF records are written with an application code. The OMFTBL is used to convert the application code to a standard abbreviation for display in this field.

RECORD TYPE — Identifies the type of record as defined in the OMF record structure and, for the detail version of the report, the type of image included in the report output. The values that can be displayed in this field are as follows:

- A = The record was added. The detail version of the report includes an image of the record that was added.
- B = The record was updated. The detail version of the report includes an image of the record before it was updated.
- C = The record was updated. The detail version of the report includes an image of the record after it was updated.
- D = The record was deleted. The detail version of the report includes an image of the deleted record.
- E = The record was read. The detail version of the report includes key data from the record after it was read.
- F = The read next function was performed. The detail version of the report includes key data from the record after it was read.
- I = An institution security violation has occurred. A user does not have access for the institution FIID to which the record belongs. The record or records are logged with a file type of I for institution security error.
- J = A file operation security violation has occurred. A user does not have authority for the function attempted. The record or records are logged with a file type of J for file operation security error.
- O = An operations screen has been accessed. The record or records are logged with a file type of O.

S = The record is either a logon or logoff record. The detail version of the report includes an image of the logon or logoff record and, for failed logon attempts, information on the reason for the failure.

GROUP — The numeric identifier for the group to which the user belongs.

USER — The numeric identifier for the user.

LNET — The identifier for logical network that the user entered on the Logon screen.

FIID — The identifier for the financial institution for which the user performed file maintenance. For logon and logoff records, this field is blank.

REGION — The identifier for the region for which the user performed file maintenance. For logon and logoff records, this field is blank.

BRANCH — The identifier for the branch for which the user performed file maintenance. For logon and logoff records, this field is blank.

TERMINAL ID — The identifier for the terminal from which the user performed the file maintenance operation, logon attempt, or logoff.

6: Protecting wireless transmissions

Access points for wireless transmission are not provided by the BASE24 system. If you set up access points for wireless transmission in networks connected to the BASE24 cardholder environment, they must be configured in accordance with Wi-Fi best practices. The use of Wired Equivalent Privacy (WEP) is prohibited for new implementation after March 31, 2009. For current wireless implementations, it is prohibited to use WEP after June 30, 2010.

Perimeter firewalls must be installed between any wireless networks and the BASE24 cardholder data environment. These firewalls must be configured to deny or control (if such traffic is necessary for business purposes) any traffic from the wireless environment into the cardholder data environment.

Wireless environments must implement strong encryption mechanisms (for example, AES) and include the following default settings:

- Encryption keys were changed from default at installation, and are changed anytime anyone with knowledge of the keys leaves the company or changes positions
- Default SNMP community strings on wireless devices were changed
- Default passwords/passphrases on access points were changed
- Firmware on wireless devices is updated to support strong encryption for authentication and transmission over wireless networks (for example, WPA/WPA2)
- Other security-related wireless vendor defaults, if applicable

7: Isolating cardholder data from the Internet

The BASE24 product is intended to be installed in an internal network zone that is segregated from the electronic demilitarized zone (DMZ). Running the application in a DMZ risks unauthorized access to the BASE24 database from the Internet. To be PCI DSS compliant, cardholder data must not be stored on Internet-accessible systems.

8: Facilitating secure remote software updates

BASE24 software updates are not delivered via remote access. Support activity can be performed using a web conferencing tool that allows ACI personnel to view what is taking place in an application. ACI does not use such a tool to deliver patches or updates. If such a tool is utilized, it must only be activated by the customer when needed and immediately deactivated after use. If customers or resellers/integrators implement remote access via VPN or other high-speed “always-on” connection, a firewall or personal firewall product must be implemented in a secure manner as per PCI-DSS Requirement 1:

Requirement	Detail
Establish firewall and router configuration standards that include the following	• A formal process for approving and testing all network connections and changes to the firewall and router configurations • Current network diagram with all connections to cardholder data, including any wireless networks • Requirements for a firewall at each Internet connection and between any demilitarized zone (DMZ) and the internal network zone • Description of groups, roles, and responsibilities for logical management of network components • Documentation and business justification for use of all services, protocols, and ports allowed, including documentation of security features implemented for those protocols considered to be insecure • Requirement to review firewall and router rule sets at least every six months
Build a firewall configuration that restricts connections between untrusted networks and any system components in the cardholder data environment. This requires that you	• Restrict inbound and outbound traffic to that which is necessary for the cardholder data environment. • Secure and synchronize router configuration files. • Install perimeter firewalls between any wireless networks and the cardholder data environment, and configure these firewalls to deny or control (if such traffic is necessary for business purposes) any traffic from the wireless environment into the cardholder data environment.

Requirement	Detail
Prohibit direct public access between the Internet and any system component in the cardholder data environment. This requires that you	• Implement a DMZ to limit inbound and outbound traffic to only protocols that are necessary for the cardholder data environment. • Limit inbound Internet traffic to IP addresses within the DMZ. • Do not allow any direct routes inbound or outbound for traffic between the Internet and the cardholder data environment. • Do not allow internal addresses to pass from the Internet into the DMZ. • Restrict outbound traffic from the cardholder data environment to the Internet such that outbound traffic can only access IP addresses within the DMZ. • Implement stateful inspection, also known as dynamic packet filtering. (That is, only "established" connections are allowed into the network.) • Place the database in an internal network zone, segregated from the DMZ. • Implement IP masquerading to prevent internal addresses from being translated and revealed on the Internet, using RFC 1918 address space. Use network address translation (NAT) technologies—for example, port address translation (PAT).
Install personal firewall software on any mobile and/or employee-owned computers with direct connectivity to the Internet (for example, laptops used by employees), which are used to access the organization's network.	

9: Facilitating secure remote access to the payment application

BASE24 software does not include a facility to provide remote access for support. But if the payment application is accessed remotely, PA-DSS requires use of two-factor authentication (user ID and password and an additional authentication item such as a smart card, token, or PIN). Support activity can be performed using a web conferencing tool that allows ACI personnel to view what is taking place in an application. ACI does not use such a tool to deliver patches or updates. If such a tool is utilized, remote access security features must be utilized. Examples of remote access security features include the following:

- Change default settings in the remote access software (for example, change default passwords and use unique passwords for each customer).
- Allow connections only from specific (known) IP/MAC addresses.
- Use strong authentication and complex passwords for logins.
 - Assign all users a unique ID before allowing them to access system components or cardholder data.
 - In addition to assigning a unique ID, employ at least one of the following methods to authenticate all users:
 - Password or passphrase
 - Two-factor authentication (for example, token devices, smart cards, biometrics, or public keys)
 - Incorporate two-factor authentication for remote access (network-level access originating from outside the network) to the network by employees, administrators, and third parties. Use technologies such as remote authentication and dial-in service (RADIUS); terminal access controller access control system (TACACS) with tokens; or VPN (based on SSL/TLS or IPSEC) with individual certificates.
 - Render all passwords unreadable during transmission and storage on all system components using strong cryptography
 - Do not use group, shared, or generic accounts and passwords.
 - Change user passwords at least every 90 days.
 - Require a minimum password length of at least seven characters.
 - Use passwords containing both numeric and alphabetic characters.
 - Do not allow an individual to submit a new password that is the same as any of the last four passwords he or she has used.
 - Limit repeated access attempts by locking out the user ID after not more than six attempts.

- Set the lockout duration to a minimum of 30 minutes or until administrator enables the user ID.
- If a session has been idle for more than 15 minutes, require the user to re-enter the password to reactivate the terminal.
- Enable encrypted data transmission.
 - Use strong cryptography and security protocols such as SSL/TLS or IPSEC to safeguard sensitive cardholder data during transmission over open, public networks. Examples of open, public networks that are in scope of the PCI DSS are:
 - The Internet,
 - Wireless technologies,
 - Global System for Mobile communications (GSM), and
 - General Packet Radio Service (GPRS).
 - Ensure wireless networks transmitting cardholder data or connected to the cardholder data environment, use industry best practices (for example, IEEE 802.11i) to implement strong encryption for authentication and transmission.
 - For new wireless implementations, it is prohibited to implement WEP after March 31, 2009.
 - For current wireless implementations, it is prohibited to use WEP after June 30, 2010.
- Configure the system so a remote user must establish a Virtual Private Network ("VPN") connection via a firewall before access is allowed.
- Enable the logging function.
- Restrict access to customer passwords to authorized reseller/integrator personnel.

10: Encryption of sensitive traffic over public networks

If you establish a connection to the BASE24 product over the Internet, you must safeguard sensitive cardholder data. Secure Sockets Layer (SSL) or Transport

Layer Security (TLS) is a typical approach to securing a session. It is the customer's responsibility to set up this tool.

Many payment applications include the use of e-mail, and other end-user messaging technologies. Note that the BASE24 application does not have any built-in end-user messaging technologies and unencrypted cardholder information should ever be transmitted using such end-user messaging technologies.

11: Encryption of all non-console administrative access

All nonconsole administrative access to the BASE24 system must be secured using SSH, VPN, or SSL/TLS. The HP NonStop system does not have *built-in* capabilities to support the use of SSH or SSL/TLS. If you communicate with the server or application, you must purchase a separate product, such as ACI's Webgate product, to secure these connections.



ACI Worldwide

Offices in principal cities throughout the world

www.aciworldwide.com

Americas +1 402 390 7600

Asia Pacific +65 6334 4843

Europe, Middle East,

Africa +44 (0) 1923 816393

© Copyright ACI Worldwide 2011

All information contained in this documentation, as well as the software described in it, is confidential and proprietary to ACI Worldwide, Inc., or one of its subsidiaries, is subject to a license agreement, and may be used or copied only in accordance with the terms of such license. Except as permitted by such license, no part of this documentation may be reproduced, stored in a retrieval system, or transmitted in any form or by electronic, mechanical, recording, or any other means, without the prior written permission of ACI Worldwide, Inc., or one of its subsidiaries.

ACI, ACI Worldwide, and the ACI product names used in this documentation are trademarks or registered trademarks of ACI Worldwide, Inc., or one of its subsidiaries.

Other companies' trademarks, service marks, or registered trademarks and service marks are trademarks, service marks, or registered trademarks and service marks of their respective companies.

About ACI Worldwide

ACI Worldwide powers electronic payments for financial institutions, retailers and processors around the world with the broadest, most integrated suite of electronic payment software in the market. More than 75 billion times each year, ACI's solutions process consumer payments. On an average day, ACI software manages more than US \$12 trillion in wholesale payments. And for more than 150 payments organizations worldwide, ACI software ensures people and businesses don't fall victim to financial crime. We are trusted globally based on our unrivaled understanding of payments and related processes. We have a definitive vision of how electronic payment systems will look in the future and we have the knowledge, scale and resources to deliver it. Since 1975, ACI has provided software solutions to the world's innovators. We welcome the opportunity to do the same for you.